

Firmware 7.15 · Block 3 audit report

Setup, recovery, storage and emulator erase · 22 September 2026

Local review judgment: No new in-scope product defect identified in the current candidate. Full and Bitcoin-only owned emulator power-cycle cases passed. The first Copilot review identified a documentation inventory issue; this revision corrects it and requires a fresh review of the resulting head.

Identity and scope

Review PR [#851](#) targets `audit/715-p02-final-review @ 92f3d00f2b75c1fe02ba3a00a7ea46b4e163c31e`. Report-generation predecessor: `455ec708e76a851b4c3960cc52d520f1a2ab6ddc`. The containing final head is recorded in the PR body after commit. Candidate source: `audit/715-scope-repair @ 614425a2a14d0113de251e7944118e47f31f5265`. Canonical release/7.15 @ `af979cd5099349ba58ec10d1b7eedeb67662c602` remains a separate line.

Line counts are from `git show --format= --numstat --no-renames COMMIT` for each historical unit and `git diff --numstat 92f3d00f2..455ec708e76a851b4c3960cc52d520f1a2ab6ddc` for the review PR at generation time. Per-commit totals include tests, docs and submodule-pointer lines; edited lines can overlap. They are not the net firmware diff. The inventory below includes the report HTML and binary PDF already present on the predecessor head, including the prior scope correction. Binary PDF counts appear as dashes. The containing commit SHA cannot be embedded in its own report; the PR body gives the resulting head.

Review PR change inventory, including report artifacts

File	Added	Deleted	Meaning
<code>docs/release/audit-units/P03-audit-report-20260922.html</code>	+19	-0	Audit document; no firmware behavior
<code>docs/release/audit-units/P03-audit-report-20260922.pdf</code>	-	-	Audit document; no firmware behavior
<code>docs/release/audit-units/P03-block-scope-20260922.md</code>	+152	-0	Audit document; no firmware behavior

The PR adds audit documentation and evidence, with no firmware code change. The final PR head can therefore be verified against the same candidate code and pins.

Exact dependency pins

Submodule	Candidate commit
<code>code-signing-keys</code>	<code>a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec</code>
<code>deps/crypto/trezor-firmware</code>	<code>8a392f70a5d5575ece3dfb35f115d4a4b27f497c</code>
<code>deps/device-protocol</code>	<code>27d3fa1f6215139cde6411f9a2882f36bb373fc9</code>
<code>deps/googletest</code>	<code>7888184f28509dba839e3683409443e0b5bb8948</code>
<code>deps/python-keepkey</code>	<code>b76ee610dd18934ee3aeeb36cfc541e8799eb46d</code>
<code>deps/qrenc/QR-Code-generator</code>	<code>6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8</code>

Submodule	Candidate commit
deps/sca-hardening/SecAESSTM32	71d356a1141624994cf613bd2d2583892e8e6d5a

Retained original P03 changes

Commit	Change	Files	Added	Deleted
8ac4bd9dfd	Setup commit authorization	4	+23	-7
2b891ceb8b	Dice collector Python pin	1	+1	-1
32df2a9aca	Stored public strings	2	+22	-5
c2197307be	Emulator sector erase	2	+25	-2
b73f7a5f75	PIN and wipe-code cleanup	1	+19	-8
f8c5692b31	Previous-word display cleanup	1	+2	-1
2e1c67e9ec	Setup staging regression	2	+30	-9
1ead40605f	Recovery backspace display	1	+19	-1
77f50c0162	Bitcoin-only migration status	1	+4	-2

Setup commit authorization · 8ac4bd9dfd

A stored setup state could be reached without the live ceremony. Commit now checks ceremony authority; native setup cases exercise rejection and legitimate completion.

File	Added	Deleted
include/keepkey/firmware/reset.h	+3	-2
lib/firmware/recovery_cipher.c	+3	-2
lib/firmware/reset.c	+6	-3
unittests/firmware/setup_ceremony.cpp	+11	-0

Dice collector Python pin · 2b891ceb8b

The host dice fixture pin moved to include collector coverage. Later pin updates supersede this pointer; current pinned host dice cases passed in the earlier CI artifact.

File	Added	Deleted
deps/python-keepkey	+1	-1

Stored public strings · 32df2a9aca

Stored public strings could reach callers without a safe terminator. Current and legacy readers bound copies and terminate them; VersionedReadersTerminateStoredStrings executed in both variants.

File	Added	Deleted
lib/firmware/storage.c	+5	-5
unittests/firmware/storage.cpp	+17	-0

Emulator sector erase · c2197307be

Emulated erase previously left data within a selected sector. Erase now sets the selected sector to flash-erased bytes; board regression executed in both variants.

File	Added	Deleted
lib/board/keepkey_flash.c	+4	-2
unittests/board/board.cpp	+21	-0

PIN and wipe-code cleanup · b73f7a5f75

Temporary PIN and wipe-code storage lingered on exit paths. The current PIN state machine clears scratch values on completion and cancellation; native suite and source path review cover this change.

File	Added	Deleted
lib/firmware/pin_sm.c	+19	-8

Previous-word display cleanup · f8c5692b31

Recovery could reuse text from a previous word. The display buffer is cleared as the screen advances; recovery native and host tests cover transitions.

File	Added	Deleted
lib/firmware/recovery_cipher.c	+2	-1

Setup staging regression · 2e1c67e9ec

Setup tests lacked direct staging and foreign-commit checks. The new case asserts staging is inert and an unrelated commit aborts; executed in both variants.

File	Added	Deleted
unittests/firmware/setup_ceremony.cpp	+4	-9
unittests/firmware/ storage_passphrase.cpp	+26	-0

Recovery backspace display · 1ead40605f

Backspace could show stale recovery text. The recovery UI now refreshes the correct prior word; host recovery/backspace cases passed in earlier CI.

File	Added	Deleted
lib/firmware/recovery_cipher.c	+19	-1

Bitcoin-only migration status · 77f50c0162

A migration status expectation did not reflect the selected variant. The test now checks the Bitcoin-only status; both variant xunit runs passed.

File	Added	Deleted
unittests/firmware/storage.cpp	+4	-2

Withdrawn or superseded historical units

Commit	Change	Files	Added	Deleted
b9b88955fa	Durable V17 replacement	2	+40	-3
0307ca0ae7	CRC-framed Python fixture pin	1	+1	-1
e8fe34811b	Bootloader replay test	1	+17	-0
06b1d249ad	Pending-record preservation lock	2	+35	-1

Durable V17 replacement · b9b88955fa

The scope repair removed or superseded this historical durability-specific work. It is not claimed as a current protection or passing test.

File	Added	Deleted
lib/firmware/storage.c	+23	-2
unittests/firmware/storage_passphrase.cpp	+17	-1

CRC-framed Python fixture pin · 0307ca0ae7

The scope repair removed or superseded this historical durability-specific work. It is not claimed as a current protection or passing test.

File	Added	Deleted
deps/python-keepkey	+1	-1

Bootloader replay test · e8fe34811b

The scope repair removed or superseded this historical durability-specific work. It is not claimed as a current protection or passing test.

File	Added	Deleted
unittests/firmware/storage_passphrase.cpp	+17	-0

Pending-record preservation lock · 06b1d249ad

The scope repair removed or superseded this historical durability-specific work. It is not claimed as a current protection or passing test.

File	Added	Deleted
lib/firmware/storage.c	+20	-1
unittests/firmware/storage.cpp	+15	-0

Later candidate interactions

Commit	Change	Files	Added	Deleted
bd5e509cd	Scope correction	8	+111	-595
6e79e57b7	Later release corrections	12	+235	-8
cd60df966	Storage and RNG corrections	10	+268	-11
f982baa65	Recovery failure display	4	+96	-9
64e5d2cb2	Final release audit fixes	12	+135	-41

Scope correction · bd5e509cd

Removed the bootloader-coupled durability batch while retaining emulator erase and unsigned version classification. The power-interruption risk remains open outside this batch.

File	Added	Deleted
docs/release/audit-units/scope-repair.md	+32	-0
include/keepkey/board/keepkey_board.h	+1	-18
include/keepkey/board/memory.h	+0	-7
lib/board/keepkey_flash.c	+0	-9
lib/board/memory.c	+7	-141
lib/firmware/storage.c	+71	-148
unittests/board/board.cpp	+0	-169
unittests/firmware/storage_passphrase.cpp	+0	-103

Later release corrections · 6e79e57b7

Recovery and storage fixes changed shared paths after the original units; current-source review and candidate-image tests assess the resulting code.

File	Added	Deleted
include/keepkey/firmware/fsm.h	+1	-0
include/keepkey/firmware/home_sm.h	+2	-0
include/keepkey/firmware/ripple.h	+8	-2
lib/board/confirm_sm.c	+5	-1
lib/firmware/fsm.c	+20	-0
lib/firmware/home_sm.c	+37	-1
lib/firmware/mayachain.c	+8	-1
lib/firmware/ripple.c	+1	-1
lib/firmware/storage.c	+8	-2
unittests/firmware/fsm.cpp	+119	-0
unittests/firmware/mayachain.cpp	+6	-0

File	Added	Deleted
unittests/firmware/ripple.cpp	+20	-0

Storage and RNG corrections · cd60df966

Subsequent storage fixes are included in the candidate image and test results, not silently attributed to an original P03 unit.

File	Added	Deleted
docs/release/7.15-COMBINED-CANDIDATE.md	+3	-2
docs/release/audit-units/copilot-followup-20260913.md	+16	-0
include/keepkey/rand/rng_health.h	+1	-0
lib/board/keepkey_flash.c	+14	-2
lib/board/memory.c	+3	-1
lib/firmware/storage.c	+12	-5
lib/rand/rng_health.c	+22	-0
unittests/firmware/recovery.cpp	+4	-1
unittests/firmware/rng_health.cpp	+37	-0
unittests/firmware/storage_passphrase.cpp	+156	-0

Recovery failure display · f982baa65

Keeps recovery cipher visible after an unrelated host failure; source review checked the display lifetime against the earlier cleanup and backspace changes.

File	Added	Deleted
include/keepkey/firmware/recovery_cipher.h	+3	-0
lib/firmware/fsm.c	+8	-1
lib/firmware/recovery_cipher.c	+30	-0
unittests/firmware/recovery.cpp	+55	-8

Final release audit fixes · 64e5d2cb2

Later audit corrections touch storage and are covered by the current candidate source review and test image.

File	Added	Deleted
.github/workflows/ci.yml	+5	-5
docs/dice-vs-coldcard.md	+1	-1
include/keepkey/board/keepkey_board.h	+2	-1
include/keepkey/board/usb.h	+0	-5
include/keepkey/firmware/signing.h	+5	-0

File	Added	Deleted
lib/emulator/libkkemu.c	+6	-0
lib/firmware/fsm.c	+6	-9
lib/firmware/signing.c	+6	-0
lib/firmware/storage.c	+13	-4
unittests/firmware/fsm.cpp	+18	-1
unittests/firmware/signing.cpp	+24	-9
unittests/firmware/thorchain.cpp	+49	-6

Findings, tests and limits

Disposition: no newly identified in-scope defect. The inherited erase-before-replacement power-interruption risk remains **open and deferred** by the release owner's scope correction; it is not a finding fixed by P03. Unknown storage versions deliberately erase on downgrade, while reserved Bitcoin-only band versions refuse without wiping.

Earlier firmware-equivalent [CI run 34951131013](#) at 7e091af157131897adc5514de392570c32088946 produced full unit artifact 10388679573, Bitcoin-only unit artifact 10389512420, and host Python artifact 10390030970. Its JUnit XML confirms executed setup, bounded string, reserved-band, staging, and sector-erase cases in both variants. The host artifact skipped five storage power-cycle cases because it lacked an owned restartable emulator. Later candidate changes affect CI workflows but not code/tests/pins relative to that firmware-equivalent run; it is supporting evidence, not exact-head workflow certification.

Owned emulator images built from this worktree close those five skips separately. Full image sha256:18f7375986270c6bdcea6155e9fe8382d5a4faca8f0466ff3bf727b759a2e9f3, Bitcoin-only image sha256:12d356b3912a0e7f76923db50368ee66e979fed3935174b6084726090a8f99db. Each ran TestStorageUpgradePreservation with KK_EMULATOR_BIN=/kkemu/bin/kkemu: 5 passed, 11 deselected. JUnit SHA256: full af033f9ec59d0f5cab3404fd41ee3a1c505bc6bc71564a56271dee1c1b8be4d5; Bitcoin-only ea0d0bf20441dbde6cef95037400de4586aa616b3e9273ed1c7f003c34968eac.

In the same images, make xunit passed: full 573 firmware, 17 board, 18 crypto, 6 Pallas constant-time; Bitcoin-only 131 firmware, 17 board, 18 crypto. Log SHA256: full 5a452156d0b2264f480ac5d640e388e1ea9ab10bf57783751bcde2fbe947459d; Bitcoin-only 4509a2ef1d05d5cdfa21401a6350fd562a48b1b6e69be3dcb14f211ee25ff49e. Logs and XML are retained in /private/tmp/kk-fw-715-p03-owned-evidence.

Remaining gates: physical OLED/recovery behavior, signed hardware upgrade, and final exact-workflow CI acceptance remain outside this Block 3 local receipt. Copilot must deliver its review on the final head; zero findings and zero unresolved threads must be checked from that delivery, not inferred from local tests.